

# Cahier des charges — NovaTech portail web

---

## 1. Identification du document

| Élément  | Valeur                                                     |
|----------|------------------------------------------------------------|
| Projet   | Projet Fil Rouge — Portail Web et infrastructure multisite |
| Client   | Novatech                                                   |
| Document | Cahier des charges fonctionnel et technique                |
| Fichier  | CDC_final.md                                               |
| Version  | 1                                                          |
| Date     | 06 10 2026                                                 |
| Statut   | Proposition à valider avant réalisation                    |

## Table des matières

1. [Identification du document](#)
2. [Contexte et enjeux](#)
3. [Objectifs du projet](#)
4. [Périmètre](#)
5. [Utilisateurs et rôles](#)
6. [Architecture fonctionnelle à deux portails](#)
7. [Exigences du portail salarié](#)
8. [Exigences du portail d'administration](#)
9. [Matrice des droits](#)
10. [Architecture technique proposée](#)
11. [Exigences de sécurité](#)
12. [Exigences non fonctionnelles](#)
13. [Navigation et écrans attendus](#)
14. [Parcours principaux](#)
15. [Critères de recette](#)
16. [Livrables](#)
17. [Organisation et jalons proposés](#)
18. [Risques et mesures de réduction](#)
19. [Hypothèses et points à valider](#)
20. [Validation](#)

### 1.1 Objet

Le présent document définit les exigences fonctionnelles, techniques, ergonomiques et de sécurité d'une plateforme Web interne destinée à une entreprise multisite.

La solution repose sur deux portails distincts :

1. un **portail salarié**, destiné aux employés et à la direction, intégré à l'Active Directory de l'entreprise ;
2. un **portail d'administration**, destiné aux techniciens et administrateurs de l'infrastructure, hébergé sur des serveurs distincts et protégé par une authentification locale avec MFA.

Les deux portails doivent être séparés afin de limiter les risques de compromission, d'appliquer des règles d'accès différentes et d'éviter qu'une interface destinée aux salariés ne permette d'atteindre directement des fonctions d'administration.

## 1.2 Sources d'expression du besoin

Le document consolide :

- les besoins fonctionnels présentés dans les documents remis par le client;
- les choix d'architecture et de sécurité formulés pour le présent projet ;
- les informations réseau documentées dans le dossier Site-B/Infrastructure.

Les choix explicites du présent cahier des charges prévalent lorsqu'ils précisent ou adaptent les propositions visibles dans ces documents.

## 2. Contexte et enjeux

L'entreprise dispose d'un siège de deux agences. Son système d'information comporte notamment :

- plusieurs sous-réseaux et VLAN ;
- des serveurs et services internes ;
- des machines virtuelles attribuées aux salariés ;
- des équipements réseau et de sécurité ;
- des tunnels VPN et des accès de télétravail ;
- des outils de supervision, de sauvegarde, de documentation et d'assistance.

Les informations sont actuellement réparties entre différents outils. L'entreprise souhaite disposer d'une interface claire pour les salariés et d'une vue technique centralisée pour les équipes d'administration, sans exposer les outils sensibles ni les protocoles d'administration sur Internet.

Les enjeux principaux sont :

- simplifier l'accès des salariés aux services autorisés ;
- appliquer le principe du moindre privilège ;
- séparer strictement les usages bureautiques des usages d'administration ;
- centraliser l'état de l'infrastructure sans contourner les outils spécialisés ;
- assurer la traçabilité des connexions, demandes et actions ;
- permettre le travail à distance au moyen d'un accès sécurisé ;
- protéger les données personnelles et techniques de l'entreprise.

## 3. Objectifs du projet

### 3.1 Objectifs métier

- Offrir aux salariés un point d'entrée unique vers leurs informations, leurs services, leur machine virtuelle et l'assistance.

- Présenter uniquement les ressources auxquelles chaque utilisateur est autorisé.
- Permettre la création et le suivi de tickets d'assistance.
- Fournir aux techniciens et administrateurs une vue structurée de l'infrastructure.
- Différencier les droits des employés, de la direction, des techniciens, des administrateurs d'agence et de l'administrateur global.
- Centraliser les informations relatives aux sites, VLAN, VPN, serveurs, VM, alertes, sauvegardes et interventions.

### 3.2 Objectifs de sécurité

- Interdire l'accès au portail salarié depuis une adresse IP qui n'appartient pas aux réseaux d'entreprise autorisés.
- Interdire l'accès au portail d'administration depuis une adresse IP qui n'appartient pas au VLAN d'administration.
- Utiliser le SSO Active Directory pour le portail salarié.
- Utiliser, pour le portail d'administration, des comptes indépendants de l'Active Directory.
- Imposer une authentification multifacteur par code à usage unique envoyé par e-mail pour le portail d'administration.
- Ne jamais exposer directement RDP, SSH, les hyperviseurs, les équipements réseau ou les consoles d'administration sur Internet.
- Journaliser les événements d'authentification et les actions sensibles.

### 3.3 Résultats attendus

À l'issue du projet, l'entreprise doit disposer :

- d'un portail salarié opérationnel et limité aux réseaux internes autorisés ;
- d'un portail d'administration séparé et limité au VLAN d'administration ;
- d'une gestion des droits fondée sur les rôles ;
- d'un mécanisme SSO pour les salariés ;
- d'une authentification locale avec MFA pour les administrateurs ;
- d'un accès sécurisé aux VM sans publication directe de RDP ou SSH ;
- d'une gestion des tickets et d'un historique des interventions ;
- d'un tableau de bord technique centralisé ;
- d'une documentation d'exploitation, de sécurité, de sauvegarde et de recette.

## 4. Périmètre

### 4.1 Inclus dans le périmètre

- conception de l'architecture web des deux portails ;
- maquettes des principaux écrans ;
- développement du portail salarié ;
- développement du portail d'administration ;
- intégration du SSO avec l'Active Directory ;
- gestion de comptes d'administration locaux et indépendants de l'AD ;
- mise en œuvre du MFA par e-mail pour l'administration ;
- filtrage des adresses IP et sous-réseaux par les pare-feu et par Nginx ;

- gestion des rôles et autorisations ;
- intégration ou mise en relation avec les services de VM, tickets, supervision, sauvegarde et documentation ;
- journalisation et supervision des deux portails ;
- tests fonctionnels, techniques et de sécurité ;
- documentation et procédures d'exploitation.

## 4.2 Hors périmètre initial

- remplacement complet de l'Active Directory ;
- remplacement des outils spécialisés de supervision, de virtualisation, de sauvegarde ou de ticketing ;
- administration directe et non contrôlée des pare-feu, switches, hyperviseurs ou serveurs depuis une page Web ;
- publication publique des portails sur Internet ;
- publication directe de RDP TCP/3389 ou SSH TCP/22 ;
- modification automatique d'une configuration réseau sans validation, journalisation et procédure de retour arrière ;
- développement d'une application mobile native.

## 4.3 Principe de livraison progressive

La première version doit privilégier la **consultation**, la centralisation des informations et les parcours sécurisés. Les opérations techniques à fort impact devront être ajoutées ultérieurement sous forme de workflows contrôlés, après validation des droits, journalisation, double contrôle si nécessaire et définition d'un retour arrière.

# 5. Utilisateurs et rôles

## 5.1 Employé

L'employé utilise exclusivement le portail salarié. Il peut :

- consulter les annonces et l'état des services qui le concernent ;
- consulter son profil ;
- modifier sa photo et certaines informations non sensibles ;
- accéder aux services autorisés ;
- rejoindre sa machine virtuelle par une passerelle sécurisée ;
- créer et suivre ses propres demandes d'assistance ;
- demander un nouveau service ou un droit supplémentaire.

Il ne peut pas :

- modifier son agence, son rôle ou ses droits ;
- consulter les données des autres salariés ;
- accéder aux fonctions techniques d'administration ;
- se connecter directement aux équipements, serveurs ou VM qui ne lui sont pas attribués.

## 5.2 Direction

Le rôle Direction dispose des fonctions du rôle Employé et peut recevoir des informations ou tableaux de synthèse métier spécifiquement autorisés. Il ne dispose d'aucun droit d'administration technique par défaut.

### 5.3 Technicien

Le technicien utilise le portail d'administration. Selon son périmètre, il peut :

- consulter l'état des services et équipements ;
- accéder aux outils de diagnostic autorisés ;
- prendre en charge, commenter et clôturer des tickets ;
- consulter la documentation et les procédures ;
- consulter les journaux nécessaires au support ;
- proposer une modification ou demander une élévation temporaire.

Il ne peut pas modifier librement les règles de sécurité, les comptes à privilèges ou les configurations critiques.

### 5.4 Administrateur d'agence

L'administrateur d'agence utilise le portail d'administration et agit uniquement sur le site ou l'agence qui lui est attribué. Ses droits peuvent inclure :

- la gestion des comptes autorisés dans son périmètre ;
- l'affectation d'une VM ;
- la consultation de l'état du réseau, des serveurs et des sauvegardes de son agence ;
- le traitement des demandes nécessitant une validation locale ;
- l'accès aux procédures d'administration autorisées.

### 5.5 Administrateur global

L'administrateur global supervise les quatre sites. Il peut consulter l'ensemble de l'infrastructure et gérer les droits d'administration. Les actions critiques restent soumises à une journalisation renforcée et, lorsque défini, à une validation préalable.

## 6. Architecture fonctionnelle à deux portails

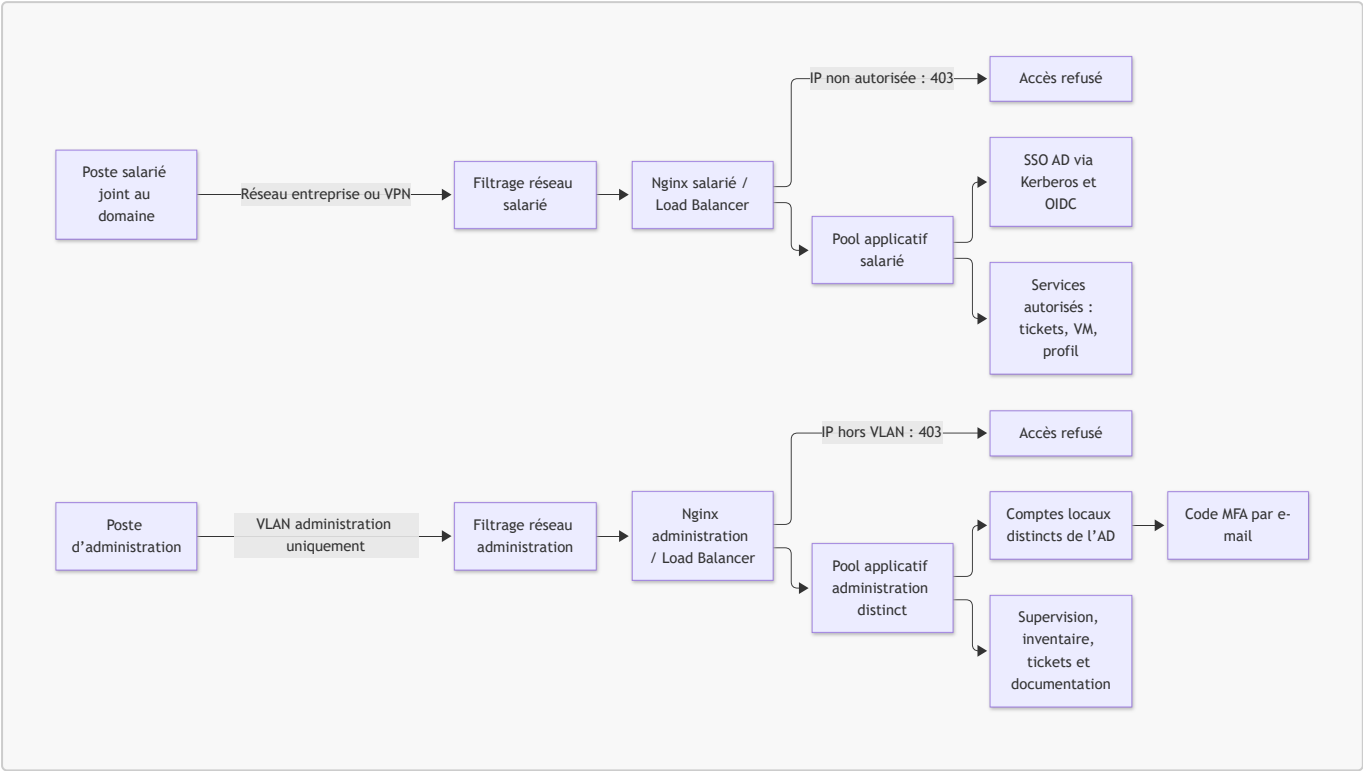
### 6.1 Séparation obligatoire

Les portails salarié et administration doivent être séparés au minimum par :

- des noms DNS distincts ;
- des serveurs Web ou groupes de serveurs distincts ;
- des configurations Nginx distinctes ;
- des comptes de service distincts ;
- des secrets et certificats distincts ;
- des bases de données ou schémas avec identifiants distincts ;
- des politiques réseau distinctes ;
- des journaux et règles d'alerte identifiables ;
- des pipelines de déploiement distincts.

Le portail salarié ne doit pas servir de passerelle vers le portail d’administration. Aucun lien d’administration ne doit être affiché aux employés.

6.2 Vue logique



6.3 Défense en profondeur

Le filtrage Nginx est obligatoire, mais ne doit pas être l’unique barrière. Les flux doivent également être limités par les ACL du réseau et les pare-feu. Une requête refusée ne doit pas atteindre l’application.

7. Exigences du portail salarié

7.1 Contrôle réseau

| ID          | Exigence                                                                                                                                                                   | Priorité |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| SAL-NET-001 | Le portail salarié doit être joignable uniquement depuis les sous-réseaux internes explicitement autorisés ou depuis un VPN d’entreprise attribuant une adresse autorisée. | Critique |
| SAL-NET-002 | Nginx doit appliquer une liste positive de CIDR autorisés et refuser toute autre adresse.                                                                                  | Critique |
| SAL-NET-003 | Une requête issue d’une adresse non autorisée doit recevoir le statut HTTP <b>403 Forbidden</b> sans redirection vers le formulaire d’authentification.                    | Critique |
| SAL-NET-004 | Les ACL réseau doivent reproduire le même principe de refus par défaut.                                                                                                    | Critique |

| ID          | Exigence                                                                                                                                                                                                 | Priorité |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| SAL-NET-005 | L'application ne doit pas faire confiance à un en-tête X-Forwarded-For fourni directement par un client. Seuls les mandataires explicitement approuvés peuvent renseigner l'adresse source de référence. | Critique |
| SAL-NET-006 | Le portail ne doit pas être publié directement sur Internet.                                                                                                                                             | Critique |

La liste définitive des réseaux salariés devra être validée avant mise en production. D'après le plan réseau actuel de Site-B, les réseaux candidats sont notamment les VLAN utilisateurs 10, 20 et 30. Le VLAN 40 est réservé à l'administration et le VLAN 50 aux serveurs ; leur accès au portail salarié devra faire l'objet d'une décision explicite.

## 7.2 Authentification SSO Active Directory

| ID           | Exigence                                                                                                                                                                            | Priorité |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| SAL-AUTH-001 | Un utilisateur déjà connecté à un poste Windows joint au domaine doit accéder au portail sans ressaisir son mot de passe.                                                           | Critique |
| SAL-AUTH-002 | Le SSO doit utiliser Kerberos/SPNEGO pour l'authentification intégrée et un protocole applicatif standard tel qu'OpenID Connect pour la session Web.                                | Critique |
| SAL-AUTH-003 | Les groupes Active Directory doivent être mappés vers les rôles de l'application.                                                                                                   | Critique |
| SAL-AUTH-004 | Le portail ne doit pas stocker le mot de passe Active Directory.                                                                                                                    | Critique |
| SAL-AUTH-005 | En cas d'échec du SSO, l'utilisateur doit recevoir un message clair et une possibilité de contacter l'assistance ; aucun compte local de secours ne doit être créé pour un salarié. | Haute    |
| SAL-AUTH-006 | La fermeture de session doit supprimer la session applicative. La durée et le renouvellement de la session doivent être configurables.                                              | Haute    |

## 7.3 Accueil et état des services

| ID           | Exigence                                                   | Priorité |
|--------------|------------------------------------------------------------|----------|
| SAL-FONC-001 | L'accueil doit afficher les annonces internes importantes. | Haute    |

| ID           | Exigence                                                                                    | Priorité |
|--------------|---------------------------------------------------------------------------------------------|----------|
| SAL-FONC-002 | L'accueil doit présenter un état simple des services accessibles à l'utilisateur.           | Haute    |
| SAL-FONC-003 | Un salarié ne doit voir que les services associés à son rôle, à son agence et à ses droits. | Critique |
| SAL-FONC-004 | Les états doivent être compréhensibles : disponible, dégradé, indisponible ou maintenance.  | Moyenne  |

## 7.4 Profil

Le profil salarié comprend au minimum :

- nom ;
- prénom ;
- adresse e-mail professionnelle ;
- agence ;
- fonction ou rôle ;
- photo facultative.

| ID          | Exigence                                                                                                                                              | Priorité |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| SAL-PRO-001 | Les attributs d'identité et d'autorisation provenant de l'AD doivent être considérés comme des données de référence en lecture seule dans le portail. | Critique |
| SAL-PRO-002 | L'utilisateur peut modifier sa photo et les données personnelles non sensibles explicitement autorisées.                                              | Moyenne  |
| SAL-PRO-003 | L'utilisateur ne peut pas modifier lui-même son rôle, son agence, son statut ou ses droits.                                                           | Critique |
| SAL-PRO-004 | Les formats, dimensions et tailles des photos doivent être contrôlés côté serveur.                                                                    | Haute    |

## 7.5 Demande de réinitialisation de mot de passe

La réinitialisation du mot de passe AD ne doit pas être réalisée automatiquement à partir d'une simple session Web.

Le processus attendu est :

1. l'utilisateur dépose une demande par un canal interne prévu à cet effet ou contacte le support s'il ne peut plus s'authentifier ;
2. la demande reçoit un numéro de ticket ;
3. un technicien autorisé vérifie l'identité selon une procédure formalisée ;
4. l'administrateur effectue la réinitialisation dans l'outil d'administration approprié ;
5. l'action, son auteur, sa date et son résultat sont consignés ;
6. l'utilisateur est contraint de choisir un nouveau mot de passe conformément à la politique de l'entreprise.

Une page interne de demande non authentifiée, si elle est retenue, doit être séparée des fonctions de réinitialisation, limitée par adresse IP, protégée contre les abus et ne jamais confirmer l'existence d'un compte.

## 7.6 Mes services

Le portail doit afficher des raccourcis vers les services autorisés, par exemple :

- intranet et applications métier ;
- assistance ;
- machine virtuelle attribuée ;
- documentation destinée aux salariés ;
- services internes propres à l'agence ou au rôle.

Les liens ne constituent pas une autorisation à eux seuls. Chaque service cible doit effectuer son propre contrôle d'accès.

## 7.7 Machine virtuelle et télétravail

| ID         | Exigence                                                                                                                                                                | Priorité |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| SAL-VM-001 | Chaque salarié autorisé au télétravail doit être associé à une VM personnelle ou à un pool explicitement défini.                                                        | Haute    |
| SAL-VM-002 | Depuis l'extérieur, le salarié doit d'abord utiliser le VPN ou la passerelle d'accès sécurisée de l'entreprise avec MFA.                                                | Critique |
| SAL-VM-003 | Le portail doit diriger le salarié uniquement vers la VM qui lui est attribuée.                                                                                         | Critique |
| SAL-VM-004 | RDP et SSH ne doivent jamais être publiés directement sur Internet.                                                                                                     | Critique |
| SAL-VM-005 | Une passerelle de type Apache Guacamole, RD Gateway ou solution VDI équivalente doit servir d'intermédiaire.                                                            | Haute    |
| SAL-VM-006 | Les fonctions de presse-papiers, transfert de fichiers, impression et redirection de périphériques doivent être désactivées par défaut puis autorisées selon le besoin. | Haute    |
| SAL-VM-007 | Les connexions distantes, leur durée et leur résultat doivent être journalisés.                                                                                         | Haute    |
| SAL-VM-008 | La désactivation d'un salarié doit entraîner la révocation de son accès distant et de son affectation.                                                                  | Critique |

## 7.8 Assistance et tickets

Chaque ticket doit comporter au minimum :

- un identifiant unique ;
- le demandeur ;
- l'agence ;
- la date et l'heure de création ;

- la catégorie ;
- une description ;
- la priorité ;
- le technicien affecté ;
- le statut ;
- l'historique des actions ;
- la date et le motif de clôture.

| ID          | Exigence                                                                                                                     | Priorité |
|-------------|------------------------------------------------------------------------------------------------------------------------------|----------|
| SAL-TIC-001 | Un salarié peut créer une demande d'assistance.                                                                              | Critique |
| SAL-TIC-002 | Un salarié peut consulter l'avancement et l'historique visible de ses propres demandes.                                      | Critique |
| SAL-TIC-003 | Une demande de service ou de droit supplémentaire doit être validée par un administrateur autorisé avant ouverture du droit. | Critique |
| SAL-TIC-004 | Toute intervention doit indiquer qui est intervenu, quand, sur quelle ressource, pour quelle raison et avec quel résultat.   | Critique |
| SAL-TIC-005 | Les commentaires internes des techniciens ne doivent pas être visibles par le demandeur sauf publication volontaire.         | Haute    |

L'intégration avec GLPI est recommandée afin de ne pas recréer un moteur complet de ticketing et de conserver une source unique pour les demandes et interventions.

## 8. Exigences du portail d'administration

### 8.1 Hébergement et contrôle réseau

| ID          | Exigence                                                                                                                                                                                | Priorité |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| ADM-NET-001 | Le portail d'administration doit être hébergé sur des serveurs distincts de ceux du portail salarié.                                                                                    | Critique |
| ADM-NET-002 | Le portail doit être accessible uniquement depuis les adresses du VLAN d'administration autorisé. Pour Site-B, le réseau est 172.16.1.96/27, conformément au schéma Site B version 1.1. | Critique |
| ADM-NET-003 | Une adresse extérieure au VLAN d'administration doit recevoir un statut HTTP 403 avant d'atteindre l'application ou la page de connexion.                                               | Critique |
| ADM-NET-004 | Les ACL du switch et du pare-feu doivent compléter le filtrage Nginx.                                                                                                                   | Critique |
| ADM-NET-005 | Le portail ne doit pas être joignable depuis les VLAN salariés, Wi-Fi, serveurs ordinaires ou Internet.                                                                                 | Critique |
| ADM-NET-006 | L'administration à distance doit nécessiter un VPN d'administration distinct, MFA et attribution d'une adresse appartenant au périmètre autorisé.                                       | Haute    |

## 8.2 Authentification locale distincte de l'AD

L'administrateur doit arriver directement sur une page de connexion. Son compte d'administration ne doit pas réutiliser son identifiant ou son mot de passe AD.

| ID           | Exigence                                                                                                                                                                                | Priorité |
|--------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| ADM-AUTH-001 | Les comptes du portail d'administration doivent être stockés dans un référentiel indépendant de l'Active Directory d'entreprise.                                                        | Critique |
| ADM-AUTH-002 | Les mots de passe doivent être hachés avec Argon2id selon des paramètres conformes à l'état de l'art ; aucun mot de passe ne doit être stocké ou journalisé en clair.                   | Critique |
| ADM-AUTH-003 | Une politique de mot de passe, de verrouillage progressif et de protection contre la force brute doit être appliquée.                                                                   | Critique |
| ADM-AUTH-004 | Après validation du premier facteur, un code à usage unique doit être envoyé à l'adresse e-mail enregistrée de l'administrateur.                                                        | Critique |
| ADM-AUTH-005 | Le code MFA doit être aléatoire, utilisable une seule fois, conservé sous forme protégée et expirer au plus tard après cinq minutes.                                                    | Critique |
| ADM-AUTH-006 | Le nombre d'essais de code doit être limité. Un code expiré, incorrect ou déjà utilisé doit être refusé.                                                                                | Critique |
| ADM-AUTH-007 | L'e-mail doit être envoyé par un relais SMTP authentifié utilisant TLS. Le code ne doit apparaître dans aucun journal applicatif.                                                       | Critique |
| ADM-AUTH-008 | La page de connexion ne doit pas révéler si l'identifiant, le mot de passe ou le code MFA est incorrect.                                                                                | Haute    |
| ADM-AUTH-009 | La session d'administration doit expirer après une période courte d'inactivité et être invalidée lors d'une déconnexion, d'un changement de mot de passe ou d'une suspension du compte. | Critique |
| ADM-AUTH-010 | L'ajout, la suspension et la suppression d'un compte d'administration doivent être journalisés et soumis à un processus d'autorisation.                                                 | Critique |

Le code par e-mail constitue la méthode de double vérification demandée pour la première version du lab. Il ne doit toutefois pas être présenté comme un mécanisme d'authentification forte conforme aux recommandations NIST SP 800-63B : cette publication exclut l'e-mail comme canal d'authentification hors bande en raison des risques d'accès au compte de messagerie, d'interception et de reroutage.

La mise en production de ce choix exige donc une acceptation formelle du risque. L'architecture devra permettre de remplacer le code par e-mail par un authentificateur TOTP ou, de préférence, WebAuthn/passkey résistant au phishing, sans remplacer le référentiel de comptes d'administration.

## 8.3 Tableau de bord

Le tableau de bord doit présenter, selon les droits :

- l'état des quatre sites ;

- l'état des liaisons VPN intersites ;
- la disponibilité des serveurs et VM ;
- les services Web indisponibles ou dégradés ;
- les principales alertes ;
- l'utilisation CPU, mémoire et disque ;
- l'état des sauvegardes et des derniers tests de restauration ;
- les tickets prioritaires ou en retard.

## 8.4 Rubriques d'administration

| Rubrique                | Informations minimales                                                 | Actions autorisées en première version              |
|-------------------------|------------------------------------------------------------------------|-----------------------------------------------------|
| Tableau de bord         | Sites, VPN, serveurs, VM, alertes                                      | Consulter et ouvrir le détail d'une alerte          |
| Utilisateurs            | Comptes d'administration, rôles, agences, statut                       | Créer, suspendre ou modifier selon le rôle          |
| Agences                 | Paris, Marseille, Montpellier, Normandie                               | Consulter la fiche et l'état d'un site              |
| Réseau                  | Sous-réseaux, passerelles, équipements, plan d'adressage               | Consulter                                           |
| VLAN                    | Identifiant, nom, sous-réseau, passerelle, fonction                    | Consulter                                           |
| VPN / accès distant     | Tunnels intersites, sessions distantes et état                         | Consulter l'état ; révoquer une session si autorisé |
| Machines virtuelles     | Nom, utilisateur, système, IP, état, site et hyperviseur               | Consulter ; affecter une VM selon validation        |
| Serveurs / services     | Web, base de données, DNS, DHCP, annuaire et services métier           | Consulter l'état et les dépendances                 |
| Pare-feu / sécurité     | Règles documentées, ACL, événements et écarts                          | Consulter ; aucune modification directe en V1       |
| Supervision             | Alertes, CPU, RAM, disque et disponibilité                             | Consulter, acquitter selon le rôle                  |
| Sauvegardes             | Date, ressource, destination, résultat et dernier test de restauration | Consulter et signaler un échec                      |
| Tickets / interventions | Demandes, priorité, technicien, statut et historique                   | Affecter, commenter et clôturer selon le rôle       |
| Documentation           | Schémas, procédures, dossiers techniques et liens Git                  | Consulter et publier selon validation               |

## 8.5 Administration des comptes et droits

- Seul un administrateur habilité peut créer ou suspendre un compte d'administration.

- Aucun compte partagé ne doit être utilisé.
- L'identité d'une personne, son rôle et son périmètre d'agence doivent être explicites.
- Un technicien ne doit pas pouvoir s'attribuer lui-même un rôle plus élevé.
- Les changements de droits doivent être historisés avec auteur, motif, date, ancienne valeur et nouvelle valeur.
- Les droits temporaires doivent comporter une date d'expiration.
- Les comptes inactifs, orphelins ou appartenant à une personne ayant quitté l'entreprise doivent être suspendus.

## 8.6 Actions techniques sensibles

En première version, le portail peut afficher l'état et la documentation des équipements, mais ne doit pas exécuter librement des commandes sur un pare-feu, un switch, un hyperviseur ou un serveur.

Toute future fonction de modification devra inclure :

- une autorisation spécifique ;
- une justification obligatoire ;
- une validation avant exécution pour les actions critiques ;
- un aperçu du changement ;
- une sauvegarde préalable ;
- un journal d'audit immuable ;
- un résultat d'exécution ;
- une procédure de retour arrière ;
- une confirmation explicite lorsque l'action est destructive.

## 9. Matrice des droits

Légende : **C** consulter, **A** agir ou modifier dans son périmètre, **V** valider, — aucun accès.

### Portail Employé

| Ressource ou fonction            | Employé     | Direction   | Technicien  | Admin d'agence | Admin global |
|----------------------------------|-------------|-------------|-------------|----------------|--------------|
| Annonces et état de ses services | C           | C           | C           | C              | C            |
| Profil personnel                 | C/A limité  | C/A limité  | C/A limité  | C/A limité     | C/A limité   |
| Services autorisés               | C           | C           | C           | C              | C            |
| VM personnelle                   | C/connexion | C/connexion | C/connexion | C/connexion    | C/connexion  |
| Création d'un ticket             | A           | A           | A           | A              | A            |
| Suivi de ses tickets             | C           | C           | C           | C              | C            |
| Demande de droit supplémentaire  | A           | A           | A           | A              | A            |

### Portail Admin

| Ressource ou fonction                               | Technicien | Admin d'agence | Admin global |
|-----------------------------------------------------|------------|----------------|--------------|
| Création d'un ticket                                | A          | A              | A            |
| Suivi de ses tickets                                | C          | C              | C            |
| Traitement des tickets                              | A local    | A/V local      | A/V global   |
| Validation d'un droit                               | —          | V local        | V global     |
| Tableau de bord technique                           | C local    | C local        | C global     |
| Utilisateurs d'administration                       | —          | C/A local      | C/A global   |
| Affectation VM                                      | —          | A local        | A global     |
| VPN et accès distant                                | C local    | C/A local      | C/A global   |
| Serveurs, services et VM                            | C local    | C/A local      | C/A global   |
| Pare-feu et sécurité                                | C local    | C local        | C global     |
| Supervision                                         | C/A local  | C/A local      | C/A global   |
| Sauvegardes                                         | C local    | C local        | C global     |
| Documentation technique                             | C local    | C/A local      | C/A global   |
| Modification directe d'un équipement critique en V1 | —          | —              | —            |

Les droits réels doivent être évalués côté serveur à chaque requête. Chaque ressource est taggée par rapport au site quelle concerne ou bien global si il s'agit d'une ressource globale. Lorsqu'une requête est effectuée, ce tag est comparé au tag de localisation du technicien ou de l'admin local avant d'exécuter la requête.

## 10. Architecture technique proposée

### 10.1 Portail salarié

Architecture recommandée :

1. un nom DNS interne dédié ;
2. un pare-feu limitant les réseaux sources aux VLAN 10, 20 et 40 ;
3. un reverse proxy/load balancer Nginx ;
4. au moins deux instances applicatives ;
5. un fournisseur d'identité compatible Kerberos et OpenID Connect, par exemple Keycloak fédéré avec l'AD ;
6. une base applicative dédiée pour les données qui ne proviennent pas de l'AD ;
7. des connecteurs limités vers GLPI, la passerelle de VM et les autres services autorisés.

Les sessions doivent être soit sans état, soit stockées dans un composant partagé protégé afin que l'équilibrage de charge n'impose pas de session locale fragile.

### 10.2 Portail d'administration

Architecture recommandée :

1. un nom DNS réservé au réseau d'administration ;
2. un filtrage réseau limité au VLAN d'administration ;
3. un Nginx et un pool applicatif distincts ;
4. une base d'identités locale dédiée ;
5. un composant d'envoi MFA via le relais SMTP ;
6. une base applicative ou un schéma dédié avec des identifiants propres ;
7. des comptes de lecture seule vers les API de supervision et d'inventaire ;
8. un collecteur de journaux centralisé.

Le portail d'administration ne doit pas réutiliser le cookie, la session, les clés de chiffrement, les comptes de service ni les secrets du portail salarié.

### 10.3 Composants proposés et justification

| Besoin                       | Solution proposée                                                           | Justification                                                                                                      |
|------------------------------|-----------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| Reverse proxy et répartition | Nginx                                                                       | Filtrage CIDR, terminaison TLS, routage, limitation de débit et équilibrage                                        |
| SSO salarié                  | Keycloak ou équivalent, fédéré à AD par LDAP/Kerberos, applications en OIDC | Sépare l'application de l'authentification et normalise les jetons et rôles                                        |
| Identités d'administration   | Base locale distincte avec mots de passe hachés avec Argon2id               | Respecte l'exigence de comptes différents de l'AD                                                                  |
| MFA administration           | Code à usage unique envoyé par SMTP TLS                                     | Conforme au parcours demandé et traçable                                                                           |
| Assistance                   | GLPI                                                                        | Outil prévu pour les tickets, les statuts, l'affectation et l'historique                                           |
| Accès aux VM                 | RD Gateway                                                                  | Évite l'exposition directe de RDP/SSH et centralise les contrôles, Windows server déjà présent dans l'architecture |
| Supervision                  | Zabbix                                                                      | Centralise disponibilité, métriques et alertes                                                                     |
| Virtualisation               | API Proxmox en lecture seule pour la V1                                     | Permet l'inventaire et l'état sans exposer la console d'administration                                             |
| Documentation                | Dépôt Git et portail documentaire avec publication contrôlée                | Versionnement, validation et traçabilité                                                                           |
| Base de données              | PostgreSQL                                                                  | Facilité de mise en place et d'administration, sauvegarde et robustesse                                            |
| Journaux                     | Loki+Promtail+Grafana                                                       | Facilité de mise en place et d'accès aux logs                                                                      |

### 10.4 Données de référence

- L'Active Directory est la source de référence des identités salariées, groupes, agences et rôles d'entreprise.
- Le référentiel local d'administration est la source des comptes privilégiés du portail d'administration.
- GLPI est la source de référence des tickets et interventions.
- Zabbix est la source de référence de l'état de supervision.
- Proxmox ou l'outil de virtualisation est la source de référence des VM et de leur état.
- Le dépôt documentaire validé est la source de référence des procédures et schémas.

Le portail doit éviter la duplication des données. Une donnée synchronisée doit indiquer sa source, sa date de dernière mise à jour et son éventuel état d'erreur.

## 11. Exigences de sécurité

### 11.1 Sécurité réseau

- Politique de refus par défaut.
- Listes positives de sous-réseaux autorisés.
- Filtrage cohérent sur le switch, le pare-feu et Nginx.
- Aucun accès public direct.
- Séparation des VLAN salariés, administration et serveurs.
- Flux interserveurs limités aux ports strictement nécessaires.
- Comptes techniques à privilèges minimaux.
- Pas de route d'administration implicite depuis un VLAN utilisateur.

### 11.2 Chiffrement

- HTTPS obligatoire sur tous les parcours.
- TLS 1.2 au minimum, TLS 1.3 privilégié.
- Certificats issus de l'autorité interne.
- Cookies Secure, HttpOnly et SameSite adaptés au parcours.
- Secrets chiffrés au repos et exclus du dépôt Git.
- Sauvegardes chiffrées et protégées par des droits distincts.

### 11.3 Sécurité applicative

- Validation côté serveur de toutes les entrées.
- Messages d'erreur sans informations techniques sensibles.
- Dépendances suivies, analysées et mises à jour.
- Audit de sécurité avant mise en production.

### 11.4 Journalisation et audit

Doivent être journalisés :

- succès et échecs d'authentification ;
- refus pour adresse IP non autorisée ;
- émission, réussite et échec d'un défi MFA, sans enregistrer le code ;
- ouverture et fermeture de session ;
- création, suspension et modification d'un compte ;

- changement de rôle ou de périmètre ;
- création, affectation, validation et clôture d'un ticket ;
- accès à une VM ;
- consultation ou export de données sensibles ;
- action technique et résultat ;
- erreur applicative significative.

Chaque événement doit comporter au minimum :

- date et heure synchronisées ;
- identifiant de corrélation ;
- utilisateur ou compte de service ;
- adresse IP source retenue ;
- action ;
- ressource ;
- résultat ;
- motif lorsqu'il est requis.

Les journaux doivent être transmis vers un stockage central protégé contre la modification par l'application. Leur durée de conservation doit être définie avec les exigences de sécurité et de protection des données.

## 11.5 Protection des données

- Collecter uniquement les données nécessaires.
- Informer les utilisateurs des traitements et de la journalisation.
- Définir une durée de conservation par catégorie de données.
- Restreindre l'accès aux photos, profils et historiques.
- Prévoir la rectification des données non issues d'un référentiel autoritaire.
- Documenter la procédure de départ d'un salarié ou administrateur.
- Respecter les obligations applicables en matière de protection des données personnelles.

## 12. Exigences non fonctionnelles

### 12.1 Disponibilité et résilience

- Les composants critiques ne doivent pas reposer sur un fichier local unique.
- Le load balancer doit retirer une instance applicative défaillante du pool.
- L'application doit exposer un contrôle de santé ne contenant aucune donnée sensible.
- Les sauvegardes doivent inclure bases, configurations, secrets chiffrés et documentation nécessaire à la restauration.
- Des tests de restauration doivent être réalisés et consignés.
- Les objectifs RPO et RTO doivent être validés avant la production.

### 12.2 Performance

Objectifs proposés, à confirmer lors du dimensionnement :

- affichage d'une page courante en moins de deux secondes au 95e percentile sur le réseau interne ;
- retour d'un refus 403 sans solliciter l'application ;

- chargement asynchrone des tableaux de supervision volumineux ;
- pagination et filtrage côté serveur ;
- absence de requêtes non bornées vers les API d'infrastructure.

## 12.3 Ergonomie et accessibilité

- Contrastes lisibles et libellés explicites.
- États et alertes compréhensibles sans dépendre uniquement de la couleur.
- Formulaires avec messages d'erreur précis.
- Interface en français pour la première version.

## 12.4 Maintenabilité

- Code versionné dans Git.
- Revue de code avant intégration.
- Configuration séparée du code.
- Variables sensibles injectées par un gestionnaire de secrets ou un mécanisme équivalent.
- Documentation d'installation, d'exploitation et de dépannage.
- Environnements de développement, recette et production distincts.

# 13. Navigation et écrans attendus

## 13.1 Portail salarié

Menu proposé :

- Accueil ;
- Mon profil ;
- Mes services ;
- Ma machine virtuelle ;
- Assistance / Mes tickets ;
- Déconnexion.

Écrans minimaux :

1. accueil avec annonces et état des services ;
2. profil salarié ;
3. liste des services autorisés ;
4. fiche de la VM attribuée et bouton d'accès sécurisé ;
5. création d'un ticket ;
6. liste et détail des tickets du salarié ;
7. page d'accès refusé ;
8. page d'indisponibilité ou d'erreur maîtrisée.

## 13.2 Portail d'administration

Menu proposé :

- Tableau de bord ;
- Utilisateurs ;

- VPN / accès distant ;
- Machines virtuelles ;
- Serveurs / services ;
- Pare-feu / sécurité ;
- Supervision ;
- Sauvegardes ;
- Tickets / interventions ;
- Documentation ;
- Déconnexion.

Écrans minimaux :

1. connexion avec identifiant et mot de passe ;
2. saisie du code MFA reçu par e-mail ;
3. tableau de bord global ou limité à l'agence ;
4. utilisateurs et rôles ;
5. état des VPN ;
6. inventaire des VM ;
7. serveurs et services ;
8. supervision et alertes ;
9. état des sauvegardes ;
10. tickets et historique d'intervention ;
11. documentation technique ;
12. journal d'audit accessible aux seuls rôles autorisés.

Les maquettes doivent être validées avant le développement des écrans définitifs.

## 14. Parcours principaux

### 14.1 Accès d'un salarié depuis l'entreprise

1. Le salarié ouvre l'URL interne.
2. Le pare-feu puis Nginx vérifient l'adresse IP source.
3. Si l'adresse n'est pas autorisée, Nginx renvoie 403.
4. Si l'adresse est autorisée, le portail déclenche le SSO.
5. L'identité AD et les groupes sont validés.
6. Le portail crée une session et calcule les droits.
7. L'utilisateur voit uniquement son espace et ses services.

### 14.2 Accès d'un salarié à distance

1. Le salarié établit le VPN ou utilise la passerelle sécurisée avec MFA.
2. Il reçoit une adresse appartenant au périmètre autorisé.
3. Il accède au portail salarié.
4. Il sélectionne sa VM.
5. La passerelle vérifie l'affectation et ouvre la session sans exposer RDP ou SSH.
6. La connexion est journalisée.

### 14.3 Accès d'un administrateur

1. L'administrateur utilise un poste situé dans le VLAN d'administration ou un VPN d'administration approuvé.
2. Le pare-feu puis Nginx valident l'adresse source.
3. Toute adresse hors périmètre reçoit un 403.
4. L'administrateur saisit son identifiant local et son mot de passe dédié.
5. Après validation, un code à usage unique est envoyé par e-mail.
6. L'administrateur saisit le code avant son expiration.
7. Le portail vérifie le code, le rôle et le périmètre d'agence.
8. La session d'administration est créée et l'événement est journalisé.

## 14.4 Demande d'un droit supplémentaire

1. Le salarié crée une demande motivée.
2. Le ticket est catégorisé et affecté.
3. Un administrateur habilité vérifie le besoin et le principe du moindre privilège.
4. La décision est enregistrée.
5. En cas d'accord, le droit est appliqué dans le référentiel autoritaire.
6. La synchronisation est contrôlée.
7. Le salarié est informé et le ticket est clôturé avec la preuve du résultat.

## 15. Critères de recette

### 15.1 Recette réseau

| Test                                                              | Résultat attendu                               |
|-------------------------------------------------------------------|------------------------------------------------|
| Accès au portail salarié depuis un réseau salarié autorisé        | Le portail répond en HTTPS et déclenche le SSO |
| Accès au portail salarié depuis un réseau non autorisé            | Réponse HTTP 403, sans page de connexion       |
| Accès au portail d'administration depuis le VLAN d'administration | La page de connexion locale est affichée       |
| Accès au portail d'administration depuis un VLAN salarié          | Réponse HTTP 403 avant authentification        |
| Accès direct depuis Internet                                      | Aucun portail n'est directement joignable      |
| Tentative RDP ou SSH directe depuis Internet                      | Flux refusé                                    |

### 15.2 Recette du portail salarié

| Test                               | Résultat attendu                                                                                     |
|------------------------------------|------------------------------------------------------------------------------------------------------|
| Salarié connecté au domaine        | Connexion transparente par SSO                                                                       |
| Utilisateur non autorisé dans l'AD | Accès refusé et événement journalisé                                                                 |
| Employé consultant les menus       | Aucun menu d'administration visible, états des services affichés, fil d'actualité entreprise affiché |

| Test                                    | Résultat attendu                                 |
|-----------------------------------------|--------------------------------------------------|
| Appel direct d'une URL d'administration | Refus côté serveur                               |
| Modification de la photo                | Modification autorisée après contrôle du fichier |
| Accès à la VM personnelle               | Seule la VM attribuée est proposée               |
| Accès à la VM d'un autre salarié        | Refus et journalisation                          |
| Création d'un ticket                    | Identifiant créé et champs obligatoires présents |
| Consultation des tickets                | Seuls les tickets autorisés sont visibles        |

### 15.3 Recette du portail d'administration

| Test                                                 | Résultat attendu                                      |
|------------------------------------------------------|-------------------------------------------------------|
| Utilisation des identifiants AD sur le portail admin | Échec de la connexion et journalisation               |
| Mot de passe local correct sans code MFA             | Session non créée                                     |
| Code MFA correct et non expiré                       | Session créée selon le rôle                           |
| Code incorrect, expiré ou réutilisé                  | Refus et journalisation                               |
| Multiples essais d'authentification                  | Limitation, verrouillage progressif et journalisation |
| Technicien ouvrant une fonction globale interdite    | Refus côté serveur et journalisation                  |
| Administrateur d'agence consultant une autre agence  | Refus et journalisation                               |
| Administrateur global consultant les trois sites     | Accès autorisé                                        |
| Consultation du portail local                        | ressources locales affichées                          |
| Affectation des VM                                   | l'admin peut affecter une VM à un utilisateur         |
| Deconnexion d'un compte admin                        | Sessions actives invalidées                           |

### 15.4 Recette de traçabilité et de restauration

- Vérifier que chaque authentification produit un événement exploitable.
- Vérifier qu'aucun mot de passe, secret ou code MFA n'apparaît dans les journaux.
- Vérifier la corrélation entre une demande, sa validation, son exécution et son résultat.
- Restaurer une sauvegarde dans un environnement isolé.
- Mesurer le temps de restauration.
- Vérifier que la documentation suffit à reprendre le service.

## 16. Livrables

- cahier des charges validé ;
- matrice des droits validée ;
- schéma d'architecture logique et réseau ;

- maquettes des écrans principaux ;
- code source des deux portails ;
- configurations Nginx ;
- configuration de l'intégration AD/SSO ;
- mécanisme de comptes locaux et MFA d'administration ;
- schéma et migrations des bases de données ;
- jeux de tests et procès-verbal de recette ;
- documentation d'installation ;
- documentation d'exploitation ;
- procédure de sauvegarde et de restauration ;
- procédure de gestion des comptes et des habilitations ;
- procédure de réponse aux incidents ;
- dossier de sécurité et liste des flux.

## 17. Organisation et jalons proposés

1. **Cadrage** : validation du périmètre, des réseaux, des rôles et des données de référence.
2. **Architecture** : validation de la séparation des portails, des flux et des composants.
3. **Maquettes** : validation des parcours Employé, Direction, Technicien et Administrateur.
4. **Socle de sécurité** : DNS, TLS, Nginx, ACL, secrets et journalisation.
5. **Portail salarié** : SSO, profil, services, VM et tickets.
6. **Portail administration** : comptes locaux, MFA, tableau de bord et rubriques techniques.
7. **Intégrations** : GLPI, Zabbix, Proxmox, passerelle de VM et documentation.
8. **Recette** : tests fonctionnels, réseau, sécurité, charge et restauration.
9. **Mise en production** : déploiement contrôlé, supervision et plan de retour arrière.
10. **Transfert** : documentation et formation des exploitants.

## 18. Risques et mesures de réduction

| Risque                                                           | Impact                            | Mesure prévue                                                                                               |
|------------------------------------------------------------------|-----------------------------------|-------------------------------------------------------------------------------------------------------------|
| Mauvaise identification de l'adresse IP source derrière un proxy | Contournement du filtrage         | N'accepter les en-têtes d'adresse que des proxies approuvés et tester le chemin complet                     |
| Compromission du portail salarié                                 | Pivot vers l'administration       | Séparation des serveurs, secrets, bases, réseaux et comptes                                                 |
| Compromission de la messagerie d'un administrateur               | Affaiblissement du MFA par e-mail | Sessions courtes, alertes, séparation des mots de passe et évolution prévue vers TOTP/WebAuthn              |
| Réutilisation du mot de passe AD pour le compte admin            | Compromission simultanée          | Politique explicite, sensibilisation et contrôle des mots de passe compromis sans stocker les mots de passe |
| Droits excessifs dans les API techniques                         | Action non autorisée              | Comptes de lecture seule en V1 et moindre privilège                                                         |

| Risque                                   | Impact                         | Mesure prévue                                                         |
|------------------------------------------|--------------------------------|-----------------------------------------------------------------------|
| Publication involontaire de RDP ou SSH   | Intrusion                      | Refus pare-feu, passerelle sécurisée et tests externes                |
| Données divergentes entre outils         | Décision erronée               | Sources de référence définies et synchronisation supervisée           |
| Journaux contenant des secrets           | Fuite de données               | Masquage, tests automatiques et revue des logs                        |
| Sauvegarde inutilisable                  | Perte de service ou de données | Tests périodiques de restauration                                     |
| Action critique déclenchée sans contrôle | Interruption de service        | Lecture seule en V1, validation et retour arrière pour les évolutions |

## 19. Hypothèses et points à valider

Les éléments suivants doivent être confirmés avant la réalisation :

1. la liste exacte des CIDR autorisés pour le portail salarié ;
2. la validation des sources autorisées du VLAN d'administration 172.16.1.96/27 pour Site-B ;
3. les noms DNS des deux portails ;
4. l'autorité de certification utilisée ;
5. le domaine AD, les groupes et attributs servant au mapping des rôles ;
6. l'outil d'identité SSO retenu ;
7. le relais SMTP et l'adresse expéditrice des codes MFA ;
8. la durée de validité du code MFA, le nombre maximal d'essais, l'acceptation formelle du risque lié au canal e-mail et la cible de migration vers TOTP ou WebAuthn ;
9. la solution d'accès aux VM : Guacamole, RD Gateway ou VDI ;
10. l'outil de ticketing retenu et le périmètre d'intégration avec GLPI ;
11. les API disponibles pour Zabbix, Proxmox, les sauvegardes et les VPN ;
12. la liste des informations que la Direction peut consulter ;
13. les durées de conservation des tickets, journaux et données de profil ;
14. les objectifs de disponibilité, RPO et RTO ;
15. le dimensionnement et le nombre d'utilisateurs simultanés ;
16. la procédure de vérification d'identité pour une réinitialisation de mot de passe ;
17. les règles d'approbation des droits temporaires et permanents ;
18. les fonctions qui resteront strictement en lecture seule lors de la première version.

## 20. Validation

Le développement ne doit commencer qu'après validation :

- du présent cahier des charges ;
- de la matrice des droits ;
- de l'architecture des deux portails ;
- de la liste des flux ;
- des maquettes ;

- des critères de recette ;
- des points ouverts ayant un impact sur la sécurité ou le périmètre.

| Rôle                             | Nom         | Décision  | Date        | Signature   |
|----------------------------------|-------------|-----------|-------------|-------------|
| Client(e) / représentante métier | À compléter | À valider | À compléter | À compléter |
| Chef de projet                   | À compléter | À valider | À compléter | À compléter |
| Référent infrastructure          | À compléter | À valider | À compléter | À compléter |
| Référent sécurité                | À compléter | À valider | À compléter | À compléter |

**Fin du cahier des charges — version 0.1**